MunichTech GmbH

INFORMATION SECURITY MANAGEMENT SYSTEM

Scope and Context Document

Document Reference	MT-ISMS-SCO-001
Version	1.2
Effective Date	[Date]
Prepared By	Austin Bond, Junior GRC Consultant
Reviewed By	[Senior GRC Partner Name], CISM, ISO LA
Approved By	CEO / Managing Director, MunichTech GmbH
Confidentiality Level	**CONFIDENTIAL** — Internal Use Only

Version	*Date*	*Author*	*Change Description*
1.0	[Date]	Austin Bond	Initial document creation; baseline ISMS scope defined following ISO 27001:2022 Clause 4.1–4.3 gap analysis
1.2	[Date]	Austin Bond	Citation correction: BaFin BAIT in the regulatory-interest table replaced with DORA (Reg. (EU) 2022/2554), applicable from 17 January 2025. No scope boundary or interested-party assessment changed.
1.1	[Date]	Austin Bond	Currency update: entity classification corrected from NIS2 Annex II to wichtige Einrichtung under Sec. 28(2) BSIG (Anlage 1); obligations restated as Sec. 30, 32, 33, 38 and 65 BSIG; registration under Sec. 33 BSIG recorded.

Table of Contents

1. Purpose
2. Scope Overview
3. Coverage Areas
    - 3.1 Business Processes
    - 3.2 Locations
    - 3.3 Technology and Systems
4. Internal and External Context
    - 4.1 Internal Context
    - 4.2 External Context
5. Interested Parties Analysis (ISO 27001:2022 Clause 4.2)
6. Information Security Objectives
7. Risk Appetite Statement
8. Exclusions and Justifications
9. Review and Maintenance
10. Sign-Off

1. Purpose

This document defines the scope and contextual boundaries of the Information Security Management System (ISMS) implemented at MunichTech GmbH, a B2B Financial Data Analytics Software-as-a-Service (SaaS) provider headquartered in Munich, Bavaria, Germany.

The document has been prepared in accordance with:

- ISO/IEC 27001:2022, Clauses 4.1 (Understanding the organization and its context), 4.2 (Understanding the needs and expectations of interested parties), and 4.3 (Determining the scope of the ISMS)
- EU NIS2 Directive (Directive 2022/2555), applicable to MunichTech GmbH as a provider of digital infrastructure services to entities in the financial sector
- DSGVO (EU General Data Protection Regulation / GDPR), governing the processing of personal data of EU data subjects
- BSI IT-Grundschutz framework principles, referenced as supplementary implementation guidance aligned with German federal security standards

The purpose of this document is to ensure that all stakeholders — internal leadership, the engineering team, external auditors, and enterprise clients — share a clear, unambiguous understanding of what is covered under the ISMS, where security controls apply, and why certain boundaries have been drawn as defined.

This document serves as the foundational anchor for all subsequent ISMS artifacts, including the Risk Register (MT-ISMS-RR-001), Statement of Applicability (MT-ISMS-SOA-001), and the Information Security Policy suite.

2. Scope Overview

The ISMS at MunichTech GmbH governs the design, development, delivery, and support of its cloud-native financial data analytics SaaS platform, including all underlying infrastructure, data processing pipelines, client-facing interfaces, and the internal processes that directly support service confidentiality, integrity, and availability.

In plain terms: The ISMS covers everything that touches how MunichTech GmbH collects, processes, stores, transmits, and protects financial data on behalf of its enterprise banking and financial services clients.

The scope boundary is defined as follows:

"The ISMS of MunichTech GmbH encompasses the development, operation, and support of its SaaS-based financial data analytics platform, hosted on Amazon Web Services (AWS) Frankfurt Region (eu-central-1), delivered from MunichTech GmbH's principal place of business at [Street Address], Munich, Germany, and accessed by enterprise clients via authenticated web interfaces and secured API integrations."

This scope statement is designed to be certifiable — precise enough to satisfy a UKAS- or DAkkS-accredited ISO 27001 certification body auditor, while remaining business-readable for client due diligence review.

A visual representation of the ISMS boundary, illustrating the relationship between the MunichTech GmbH HQ, AWS eu-central-1 environment, remote workforce, and external client/supplier interfaces, is documented in Appendix A — ISMS Boundary Diagram (MT-ISMS-SCO-001-A).

3. Coverage Areas

3.1 Business Processes

Included Processes

Process	*Description*	*Risk Relevance*
Platform Development & Release Management	Agile software development lifecycle (SDLC), CI/CD pipeline management, code review, and secure release gating for the SaaS platform	HIGH — Source code and deployment pipeline integrity are critical assets
Client Data Ingestion & Processing	Automated ingestion of structured financial datasets (e.g., transaction records, portfolio data) from enterprise clients via encrypted API endpoints; transformation and analytics processing	CRITICAL — Core business function; handles confidential financial data under contractual and regulatory obligation
Client Identity & Access Management	Provisioning, de-provisioning, and lifecycle management of client and internal user accounts across the platform	HIGH — Unauthorized access represents the primary threat vector
Incident Detection & Response	24/7 monitoring via SIEM, alert triage, escalation, and response procedures including NIS2-mandated reporting workflows	CRITICAL — § 32 BSIG (NIS2 Art. 23) imposes 24-hour early warning and 72-hour notification obligations
Vulnerability & Patch Management	Regular scanning (minimum fortnightly), risk-based prioritization, and SLA-governed remediation of identified vulnerabilities across infrastructure and application layers	HIGH — Unpatched systems represent direct exploitable risk to client data
Supplier & Third-Party Risk Management	Due diligence, contractual security obligations (DPA, AVV), and ongoing monitoring of third-party vendors including AWS,	HIGH — ISO 27001:2022 Annex A 5.19–5.22; DSGVO Art. 28 compliance

	subprocessors, and SaaS tooling providers	
Business Continuity & Disaster Recovery	RTO/RPO-governed recovery planning, regular DR testing, and AWS multi-AZ failover configuration	HIGH — SLA commitments to banking clients require defined uptime guarantees
Human Resources Security	Pre-employment screening, onboarding/offboarding security procedures, security awareness training	MEDIUM-HIGH — Insider threat and social engineering mitigation
Legal, Compliance & Audit Management	DSGVO compliance monitoring, regulatory reporting, internal ISMS audit cycle, and external certification audit coordination	HIGH — Regulatory non-compliance is a direct business and reputational risk

Excluded Processes

Excluded Process	*Justification*
Physical product manufacturing or logistics	MunichTech GmbH is a pure SaaS provider; no physical goods are produced or distributed
Non-MunichTech GmbH client IT environments	Client-side infrastructure is outside MunichTech GmbH's operational control. Security requirements are addressed contractually via Data Processing Agreements (DPA/AVV) and client onboarding security checklists
AWS global infrastructure management	AWS operates under the AWS Shared Responsibility Model. AWS is responsible for security of the cloud (physical data centers, hypervisor, global network). MunichTech GmbH is responsible for security in the cloud (OS configuration, application layer, IAM, data classification)

3.2 Locations

In-Scope Locations

Location	*Type*	*Description*
MunichTech GmbH HQ, Munich, Bavaria, Germany	Primary Office	Houses all 50 employees. All development, operations, sales, HR, and executive functions are performed here. Physical security controls (access control, CCTV, clean desk policy) apply
AWS Frankfurt Region (eu-central-1)	Cloud Infrastructure	Primary production environment. All client data is processed and stored exclusively within this region. Data residency within Germany/EU is a contractual and DSGVO compliance requirement for financial sector clients
Remote Working Locations (Employee Home Offices)	Virtual/Distributed	MunichTech GmbH operates a hybrid working policy. Remote endpoints are governed by the Remote Working & Clear Desk Policy (MT-POL-007) and must comply with enforced device management controls (MDM via Microsoft Intune)

Out-of-Scope Locations

Location	*Justification*
AWS regions outside eu-central-1	No production data is processed or stored outside the Frankfurt region. Any use of non-EU AWS regions (e.g., for development/testing) is prohibited by the Data Classification and Handling Policy (MT-POL-003) and documented in the DSGVO Records of Processing Activities (RoPA)
Third-party client premises	Outside MunichTech GmbH's operational and contractual control boundary

3.3 Technology and Systems

Systems In-Scope

System / Platform	*Function*	*Key Security Controls Referenced*
AWS Infrastructure (eu-central-1)	Core production hosting — EC2, RDS (PostgreSQL), S3, Lambda, VPC, CloudTrail, GuardDuty	AWS Config for compliance posture; VPC flow logs; encryption at rest via AWS KMS (AES-256); TLS 1.2+ in transit — ISO 27001:2022 Annex A 8.24 (Cryptography)
SaaS Analytics Platform (Proprietary)	Client-facing financial data analytics application	OWASP Top 10 hardening; SAST/DAST integrated into CI/CD pipeline (e.g., SonarQube, OWASP ZAP) — Annex A 8.25–8.29 (Secure Development)
Okta (Identity Provider)	SSO and MFA enforcement for all internal systems and AWS console access	Phishing-resistant MFA enforced (FIDO2/WebAuthn); Conditional Access Policies; automated deprovisioning via SCIM — Annex A 5.15–5.18 (Access Control)
GitHub Enterprise	Source code repository and CI/CD pipeline orchestration	Branch protection rules; mandatory signed commits (GPG); secrets scanning enabled; no hardcoded credentials policy — Annex A 8.4, 8.8
Microsoft 365 (E3/E5)	Corporate email, collaboration (Teams), document management (SharePoint)	Microsoft Purview DLP policies; conditional access; email encryption for sensitive communications; Intune MDM for endpoint management — Annex A 8.12 (Data Leakage Prevention)
Splunk / AWS Security Hub	SIEM and centralized log management	Log retention minimum 12 months (hot) + 24 months (cold/S3 Glacier); alerting rules aligned to MITRE ATT&CK framework; NIS2 incident detection baseline — Annex A 8.15, 8.16
Jira (Atlassian Cloud)	Project management, vulnerability tracking, incident ticketing	Access restricted to authenticated users; audit logs enabled; classified project spaces for security incidents — Annex A 5.10
Confluence (Atlassian Cloud)	ISMS documentation management and internal knowledge base	Document access controls aligned to data classification; version control enforced — Annex A 5.10

BambooHR	HR information system — employee records, onboarding/offboarding workflows	Access restricted to HR and executive management; DSGVO-compliant data retention schedules configured; Betriebsrat information rights per BetrVG § 80; personnel data handling subject to co-determination under BetrVG § 94 — Annex A 6.1, 6.2

Excluded Systems

System	*Justification*
Personal employee devices (unmanaged)	Personal devices are prohibited from accessing MunichTech GmbH systems. BYOD is not permitted; all endpoint access requires Intune-enrolled, company-managed devices per MT-POL-007
Client-owned analytics or BI tools	Outside MunichTech GmbH's management boundary. Covered only through API security requirements documented in client-facing Technical Security Addenda

4. Internal and External Context

This section fulfills ISO 27001:2022 Clause 4.1 requirements.

4.1 Internal Context

Organizational Structure

MunichTech GmbH employs 50 full-time staff organized across five functional departments:

Department	*Headcount (Approx.)*	*ISMS Relevance*
Engineering & DevOps	~20	Highest — direct control over platform security architecture
Product & Data Science	~10	High — design decisions with security implications; data handling
Sales & Client Success	~8	Medium — handles client contractual data; social engineering risk
Operations & Finance	~7	Medium — financial data access; procurement of third-party tools

HR & Administration	~5	Medium — manages the employee lifecycle; Betriebsrat interface

Note on Works Council (Betriebsrat): MunichTech GmbH has an active Betriebsrat. Per Betriebsverfassungsgesetz (BetrVG) § 87, the Betriebsrat has co-determination rights over the introduction of technical systems capable of monitoring employee behavior or performance. Any ISMS controls involving employee monitoring (e.g., DLP tooling, email monitoring, endpoint activity logging) must be subject to a Betriebsvereinbarung (works agreement) prior to implementation. The Legal & Compliance team is responsible for coordinating this process. This is a non-negotiable German legal obligation and is tracked as a compliance requirement in the ISMS.

Resources & Capabilities

Resource Area	*Current State*	*ISMS Implication*
Budget	Dedicated ISMS implementation budget allocated for FY2025, covering tooling, external audit, and certification fees	Sufficient for MVP certification scope; reviewed annually
Personnel	No dedicated full-time CISO; IT Security function held by the Head of Engineering with external GRC advisory support	Key person risk identified; risk treatment tracked in Risk Register (MT-ISMS-RR-001, Risk ID: HR-003)
Technology Maturity	Cloud-native AWS environment with moderate security tooling maturity; GuardDuty and CloudTrail active; SIEM partially configured	Gap remediation roadmap documented in ISMS Project Plan (MT-ISMS-PP-001)
Security Culture	Annual security awareness training in place; no formal phishing simulation program yet	Phishing simulation program scheduled for Q3 2025

4.2 External Context

Regulatory and Compliance Requirements

Regulation / Standard	*Applicability*	*Key Obligations for MunichTech GmbH*
ISO/IEC 27001:2022	Contractual — required by enterprise banking clients as a prerequisite for vendor onboarding	Full ISMS implementation and third-party certification by a DAkkS-accredited certification body
EU NIS2 Directive (Directive 2022/2555)	Legal — MunichTech GmbH qualifies as a wichtige Einrichtung (important entity) under § 28(2) BSIG — Anlage 1, Sektor 6 Digitale Infrastruktur, Einrichtungsart IKT-Dienstleistungsmanagement (B2B). At 50 employees and €12.4m turnover the company exceeds the important-entity threshold (>49 employees or >€10m) and remains below the particularly-important tier. Registration under § 33 BSIG was completed; applicability was confirmed against the BSI NIS-2-Betroffenheitsprüfung.	Registration with BSI; implementation of 10 baseline security measures (Art. 21); 24-hour early warning + 72-hour incident notification to BSI (Art. 23); executive liability provisions
DSGVO / GDPR	Legal — processes personal data of EU data subjects (client contact data, user accounts)	Lawful basis documentation; Data Processing Agreements (Auftragsverarbeitungsvertrag / AVV) with all processors; RoPA maintenance; 72-hour breach notification to Bayerisches Landesamt für Datenschutzaufsicht (BayLDA)
BSI IT-Grundschutz	Voluntary — referenced as supplementary implementation guidance	BSI Grundschutz Compendium used as technical reference for control implementation, particularly for cloud (OPS.2.2) and web applications (APP.3.1)
Kreditwesengesetz (KWG) / DORA	Indirect — client-imposed — banking clients subject to BaFin regulation may flow down DORA (Reg. (EU) 2022/2554) security requirements via contractual obligations	MunichTech GmbH must demonstrate security controls meeting DORA expectations as part of client vendor assessments

Market and Industry Factors

Factor	*Detail*	*ISMS Implication*
Enterprise Banking Sales Cycle	ISO 27001 certification is a hard gate for procurement decisions at Tier-1 German and European banks	Certification timeline directly impacts revenue; ISMS must be certification-ready by Q4 2025
Financial Sector Threat Landscape	Financial data analytics platforms are high-value targets for ransomware, API abuse, and supply chain attacks (ref: ENISA Threat Landscape 2024)	Risk Register must reflect sector-specific threat actors (TA505, Carbanak-affiliated groups); threat intelligence feeds integrated into SIEM
Competitive Landscape	European SaaS competitors increasingly use ISO 27001 + SOC 2 Type II as market differentiators	Dual-framework alignment (ISO 27001 primary; SOC 2 as future phase) considered in control design to avoid redundant implementation effort
Client Due Diligence Pressure	Enterprise clients conduct annual Vendor Security Assessments (VSA); questionnaire responses require evidenced controls	ISMS documentation structure is designed to map directly to common VSA frameworks (SIG Lite, CAIQ)

5. Interested Parties Analysis

This section fulfills the mandatory requirements of ISO 27001:2022 Clause 4.2. MunichTech GmbH has identified the following interested parties as having relevant needs and expectations with respect to information security.

Interested Party	*Type*	*Key Needs & Expectations*	*ISMS Response*
Enterprise Banking & Financial Services Clients	External	ISO 27001 certification; contractual SLA uptime guarantees; DSGVO-compliant data handling; audit rights	Certification target Q4 2025; DPAs in place; annual client audit support
Bundesamt für Sicherheit in der Informationstechnik (BSI)	External / Regulatory	NIS2 registration; timely incident reporting; implementation of Art. 21 measures	NIS2 registration completed; incident response plan includes BSI notification workflow
Bayerisches Landesamt für Datenschutzaufsicht (BayLDA)	External / Regulatory	DSGVO compliance; breach notification within 72 hours	RoPA maintained; breach notification SOP in place (MT-IRP-003)

AWS (Cloud Infrastructure Provider)	External / Supplier	MunichTech GmbH operates within the AWS Shared Responsibility Model	AWS used under documented DPA/AVV; security configuration reviewed quarterly against AWS Security Hub findings
DAkkS-Accredited Certification Body	External	Auditable ISMS; complete documentation; evidence of operational effectiveness	All ISMS documents version-controlled in Confluence; evidence repository maintained
MunichTech GmbH Board / Managing Directors	Internal	Business continuity; reputational risk management; revenue protection via certification	ISMS KPIs reported to board quarterly; executive accountability defined in ISMS Charter
Employees	Internal	Clear security policies; fair and transparent monitoring practices; data privacy	Policies communicated via onboarding and annual training; Betriebsvereinbarung governs monitoring tools
Betriebsrat (Works Council)	Internal / Legal	Co-determination rights under BetrVG § 87 for monitoring systems; employee data protection	Formal consultation process for all new monitoring-capable tools; documented Betriebsvereinbarungen
Third-Party Subprocessors & SaaS Vendors	External / Supplier	Clear contractual security requirements; DPA compliance	Supplier security policy (MT-POL-009) and AVV templates applied to all processors
Cyber Liability Insurer	External	Documented security controls; evidence of risk management maturity	ISMS documentation shared as part of annual insurance renewal underwriting

6. Information Security Objectives

Aligned with ISO 27001:2022 Clause 6.2. Objectives must be measurable, monitored, and reviewed.

#	*Objective*	*Metric / KPI*	*Target*	*Owner*	*Review Frequency*
1	Protect the confidentiality of client financial data against unauthorized access or disclosure	Zero confirmed unauthorized data disclosures	100% MFA coverage; 0 confirmed breaches	CISO / Head of Engineering	Quarterly

		per year; MFA adoption rate across all systems			
2	Ensure platform availability meeting contractual SLA commitments	Platform uptime measured via AWS CloudWatch; RTO/RPO adherence in DR tests	≥ 99.9% monthly uptime; RTO < 4 hours	Head of Engineering / DevOps	Monthly
3	Achieve and maintain ISO 27001:2022 certification	Successful Stage 1 and Stage 2 certification audit with zero major non-conformities	Certification by Q4 2025; zero major NCs at surveillance audits	GRC Lead	Annual
4	Maintain full compliance with DSGVO/GDPR and NIS2 obligations	Zero overdue breach/incident notifications; 100% DPA coverage of processors	0 regulatory findings; 100% processor DPA coverage	Legal & Compliance	Quarterly
5	Reduce the organizational attack surface through continuous vulnerability management	Mean Time to Remediate (MTTR) critical vulnerabilities; percentage of systems with current patches	Critical: MTTR ≤ 72 hours; High: MTTR ≤ 14 days	Head of Engineering	Monthly
6	Build and sustain a security-aware organizational culture	Phishing simulation click rate; completion rate of annual security awareness training	< 5% phishing click rate; 100% training completion	HR / GRC Lead	Bi-Annual

7. Risk Appetite Statement

MunichTech GmbH operates in a regulated, high-trust environment serving financial sector clients. The following risk appetite statement establishes the decision-making framework governing all risk treatment selections documented in the Risk Register (MT-ISMS-RR-001).

Risk Domain	*Risk Appetite*	*Rationale*
Client Data Confidentiality	Near-Zero Tolerance	Regulatory obligation (DSGVO) and contractual duty of care to banking clients; a single breach could result in client loss, regulatory sanction, and reputational damage that is disproportionate to the company's size
Platform Availability	Low	SLA commitments to enterprise clients carry contractual penalty clauses; downtime has direct revenue and reputational consequence
Regulatory Compliance (NIS2, DSGVO)	Zero Tolerance	Non-compliance carries personal executive accountability under § 38 BSIG (NIS2 Art. 20) and administrative fines of up to €7,000,000 or 1.4% of global annual turnover (§ 65 BSIG, transposing NIS2 Art. 34 — important-entity tier) / €20,000,000 or 4% of global annual turnover (GDPR Article 83(4)).
Internal Operational Risk	Moderate	Accepts some operational inefficiency risk in exchange for agility in product development, managed through DevSecOps practices
Third-Party / Supply Chain Risk	Low-Moderate	Actively managed through supplier due diligence; cannot achieve zero — accepts residual risk with compensating controls

Note: Risks assessed as HIGH or CRITICAL (as defined in the MunichTech GmbH Risk Register MT-ISMS-RR-001) that fall outside the stated risk appetite require documented, board-approved risk treatment decisions before acceptance.

8. Exclusions and Justifications

ISO 27001:2022 Clause 4.3 requires that any exclusion of Annex A controls is justified and does not undermine the organization's ability to achieve ISMS objectives.

Excluded Item	*Type*	*Justification*	*Residual Risk / Compensating Control*
Physical security of AWS data centers	Infrastructure	AWS operates under the Shared Responsibility Model. Physical security of eu-central-1 data center facilities is solely AWS's responsibility. AWS maintains ISO 27001, SOC 2 Type II, and C5 (BSI Cloud Computing Compliance Criteria Catalogue) certifications covering physical controls	Residual risk accepted; mitigated by contractual relationship with AWS and reliance on AWS compliance certifications reviewed annually
Non-eu-central-1 AWS Regions	Location	No MunichTech GmbH production data is processed or stored outside the Frankfurt region. Use of other regions is prohibited by policy	Data residency controls enforced via AWS SCP (Service Control Policies) at organizational level preventing resource creation outside eu-central-1
Client-side IT environments	Organizational Boundary	MunichTech GmbH does not manage, operate, or have visibility into client IT infrastructure. Security obligations on the client side are governed by contract (Technical Security Addendum)	Clients provide annual self-attestation of their security posture; API access to MunichTech GmbH platform requires client-side certificate authentication
ISO 27001 Annex A Control 6.4 (Disciplinary Process)	Control	Disciplinary process is governed by German labor law (Arbeitsrecht) and Betriebsrat co-determination rights. Formal security-related disciplinary procedures are	HR Policy (MT-HR-POL-002) references security misconduct; Betriebsvereinbarung governs process

		embedded within the existing HR framework agreed with the Works Council and are not maintained as a standalone ISMS document	

9. Review and Maintenance

This Scope and Context Definition document shall be reviewed:

- **Annually** — as part of the ISMS Management Review cycle (ISO 27001:2022 Clause 9.3)

- **Upon significant organizational change** — including but not limited to: expansion into new markets or geographies, acquisition of a new entity, migration to a new cloud provider, material change in regulatory obligations, or a significant information security incident
- **Following major regulatory updates** — e.g., entry into force of the German NIS-2-Umsetzungsgesetz (BGBl. 2025 I Nr. 301) and the revised BSIG, updates to BSI IT-Grundschutz, or new BaFin guidance affecting financial sector vendor requirements

Event	*Review Trigger Owner*	*Target Review Completion*
Annual ISMS Management Review	GRC Lead	April 2026
Significant organizational change	Department Head / GRC Lead	Within 30 days of change
Regulatory update	Legal & Compliance	Within 60 days of published update

Document Repository: This document is maintained in the ISMS Confluence space (MT-ISMS / Scope & Context) under version control. Superseded versions are archived and not deleted, in accordance with ISO 27001:2022 Clause 7.5 (Documented Information) and DSGVO documentation retention requirements.

DOCUMENT APPROVAL

PREPARED BY	
Name	Austin Bond
Title	Junior GRC Consultant
Date	[Date]
Signature	
REVIEWED BY	
Name	[Senior GRC Partner Name]
Title	Senior GRC Partner, CISM | ISO 27001 Lead Auditor
Date	[Date]
Signature	
APPROVED BY	
Name	[CEO / Managing Director Name]
Title	Chief Executive Officer, MunichTech GmbH
Date	[Date]
Signature	